

01 — Operator Decisions

(BLOCKING — Resolve FIRST)

Revision: 1 **Parent:** 00_MASTER_INDEX.md **Status:** OPERATOR-GATED — 12 decisions, zero code changes, must be resolved before agent-executable work begins on Stages C/D/E/F.

§1. A-01 + A-02 — Multi-Tenant Accounts Design Decisions

Source: docs/research/accounts/30_delivery_plan.md §5, K12 in PRODUCTION_READINESS_PLAN.md

These decisions determine the ENTIRE shape of the multi-tenant Accounts feature. Without them, M1 (data model + migrations) cannot start.

A-01a — Permission model

Question: RBAC-first hybrid (accounts → projects, each with roles) OR flat tenant-scoping (no project-level RBAC)? **Recommendation:** RBAC-first hybrid (matching the existing project-role design). **Impact:** Determines whether ProjectAccess role tables are per-account-scoped or account-global.

A-01b — Identity source

Question: Local accounts only (users stored in PostgreSQL, bcrypt passwords) OR OAuth2/OIDC federation (Google, GitHub, etc.)? **Recommendation:** Local accounts for MVP; OAuth2 as a follow-up seam. **Impact:** Determines whether we add a real User table with password hashing vs an external IdP integration.

A-01c — ID type

Question: TEXT (UUID strings, human-readable) OR UUID (native PostgreSQL UUID type)? **Recommendation:** TEXT (matches existing `device_id`, `artifact_id`, etc. — consistent with current codebase). **Impact:** Affects every table's FK column type and the token `account_id` claim format.

A-02a — Per-account signing keys

Question: One global Ed25519 keypair for ALL accounts OR per-account keypairs? **Recommendation:** Per-account keypairs (stronger tenant isolation; M7 object-storage seam design assumes this). **Impact:** Determines the signing-key registry design and key rotation strategy.

A-02b — Default-account backfill

Question: When Accounts lands, what happens to existing devices/artifacts/deployments that have no `account_id`? Migrate to a `__default__` account OR require operator to assign? **Recommendation:** Migrate to a `__default__` account (migration 003 in the Accounts plan). **Impact:** Determines whether the migration is a safe backfill or a destructive blocking operation.

§2. A-03 — Marketing Website Design Decisions

Source: `docs/research/website/00_WEBSITE_DESIGN_AND_BUILD_PLAN.md`
§8.6, K13 in `PRODUCTION_READINESS_PLAN.md`

A-03a — Repo name and remote

Question: New submodule repo name? `vasic-digital/helix_ota_website` (existing, contains scaffolds) or new? **Recommendation:** Use existing submodules/`website` (already registered in `.gitmodules`, already has scaffolding at commit 9abb15e). **Impact:** Zero new repo creation if using existing; just build on the scaffold.

A-03b — Containerized build

Question: Build the website via rootless podman container (§11.4.173/§11.4.161) OR host-direct npm build? **Recommendation:** Containerized build (constitution-mandated §11.4.173 for ALL builds). **Impact:** Requires a Dockerfile in the website repo; build script in scripts/remote_deploy/deploy_website.sh already expects this.

A-03c — OpenDesign tokens-only vs full component library

Question: Use only OpenDesign brand tokens (tokens.css, Tailwind v4 theme) OR the full @open-design/components library? **Recommendation:** Tokens-only (the full component library pins React 18.3.1 — conflicts with ota-manager’s React 19). **Impact:** Determines which npm packages are installed and whether component conflicts are an issue.

§3. A-04 — Mirror-Fork Canonicalization

Source: PRODUCTION_READINESS_PLAN.md K1, CONTINUATION.md

Three owned submodules have diverged mirrors across GitHub (HelixDevelopment org) and GitLab (vasic-digital org). Their gitlinks CANNOT be bumped until the canonical mirror is chosen and divergent branches are UNION-merged (never force-push §11.4.113).

Affected submodules:

Submodule	GitHub (HelixDevelopment)	GitLab (vasic-digital)	Divergence
vision_engine	a97df79 (main)	b417a40 (master)	master diverges HD has gov- doc commits;
llm_orchestrator	bde36431	9c9db1dc	VD has original; main-vs- master

Submodule	GitHub (HelixDevelopment)	GitLab (vasic-digital)	Divergence
llm_provider	4749d46 (+16.8k lines)	8905a76 (+647 lines)	REAL code fork — different Go files

Decision per submodule:

- **Which org is canonical?** (HelixDevelopment or vasic-digital)
- **Which branch is canonical?** (main or master)
- **How to reconcile:** UNION-merge divergent branches onto canonical, retire non-canonical branch, NEVER force-push.

Fixed and preserved locally:

- vision_engine: 6 defect fixes committed locally at 1ec0c57, publish blocked
- llm_orchestrator: 3 defect fixes + 3 RED tests preserved to scratchpad, not committed
- llm_provider: 1 nil-ctx crash fix preserved to scratchpad, not committed

§4. A-05 — DDoS Default Posture

Source: PRODUCTION_READINESS_PLAN.md K14

Question: What should HELIX_MAX_INFLIGHT default to? - **Option A:** 256 (conservative — safe for production, limits concurrent requests) - **Option B:** 0 = UNLIMITED (current default — operator must explicitly configure, OOM risk)

Recommendation: 256 (production-safe default; operator can raise for high-throughput deployments). **Impact:** Affects every deployment. The gap tracker G-21 claims this is “Closed” (default changed to 1000) but the production compose still ships with the old default. This needs the decision to settle the ACTUAL number.

§5. A-06 — ROLL-1: SuccessThreshold==0 Canary Semantics

Source: PRODUCTION_READINESS_PLAN.md K3

Question: When SuccessThreshold is 0 in a rollout phase, any single success passes the canary phase with no real gate. Should the engine: -

Option A: Reject SuccessThreshold==0 at config-validation time (fail-fast, safe) - **Option B:** Document as “by-design symmetric canary: any-success-passes” (permissive, operators choose)

Recommendation: Option A (reject at validation — “when in doubt, halt” per rollout engine design philosophy). **Impact:** Affects rollout engine behavior. Breaking change if any deployment already uses SuccessThreshold==0.

§6. A-07 — OTA Signing Metadata Crypto-Binding Scope

Source: PRODUCTION_READINESS_PLAN.md K4

Question: Should the Ed25519 artifact signature cover ONLY the SHA-256 payload digest (current) OR the digest PLUS targeting metadata (OSType, Board, Version)? - **Option A:** Digest only (current — simpler, metadata is upload-auth-gated, S4/S5 validate separately) - **Option B:** Digest + metadata (crypto-binds targeting — prevents relabel-replay attacks)

Recommendation: Option B for 1.1.0 (stronger supply-chain security); keep Option A for 1.0.0 (already shipped). **Impact:** Breaking change to artifact format. Requires coordinated client and server update. TUF integration (ADR-0002 §4) partially addresses this at a higher level in 1.0.1+.

§7. A-08 — Remote Deploy Host Configuration

Source: docs/remote_deploy/REMOTE_DEPLOY.md §6, QD1–QD6

A-08a — Host identity

Question: What is the production host IP/hostname? (ADDRESS_HXOTA in deploy env) **Current:** hxota placeholder in scripts.

A-08b — SSH authentication

Question: SSH key auth OR password auth? **Recommendation:** SSH key auth (HXOTA_SSH_USE_PASSWORD=0 + HXOTA_SSH_KEY). **Impact:** Password mode leaks secrets via SSHPASS; key auth is passwordless and secure.

A-08c — Host bootstrap ownership

Question: Who prepares the host? (create hxota user, install rootless podman + podman-compose, loginctl enable-linger hxota, set net.ipv4.ip_unprivileged_port_start=80) **Note:** The deploy pipeline NEVER uses root (§11.4.161).

A-08d — Sword product scope

Question: What is the Mistiq/VADER board ID + OS type? **Current:** atmosphere target known (os_type=android, board=rk3588_t); mistiq_vader is a placeholder in deploy/sword/products/mistiq_vader.env.example.

§8. A-09 — lets_encrypt + sftp Submodule Paths

Source: docs/remote_deploy/REMOTE_DEPLOY.md §5

A-09a — lets_encrypt submodule

Question: Canonical path — submodules/lets_encrypt/ (grouped) OR repo-root lets_encrypt/ (flat)? **Recommendation:** submodules/lets_encrypt/ (grouped, consistent with other submodules). **Repo:** git@github.com:vasic-digital/lets_encrypt.git **Status:** NOT on disk. Must be git submodule add'd. **CLI confirmation:** The https_certs.sh wrapper calls a placeholder CLI — confirm the actual lets_encrypt.sh entrypoint against the submodule README before live use (§11.4.99).

A-09b — sftp submodule

Question: Canonical path — submodules/sftp/ (grouped) OR repo-root sftp/ (flat)? **Recommendation:** submodules/sftp/ (grouped). **Repo:** git@github.com:vasic-digital/sftp.git **Status:** NOT on disk. Must be git submodule add'd. **CLI confirmation:** Same as lets_encrypt — confirm the actual CLI before use.

§9. A-10 — hxota.dev Root Behavior

Source: docs/remote_deploy/REMOTE_DEPLOY.md QD5

Question: What should hxota.dev serve at /? - **Option A:** The console SPA (ota-manager — operator/admin login) - **Option B:** Redirect to hxota.com (marketing website)

Recommendation: Option A (console at /; hxota.com is the separate marketing domain). **Impact:** Affects nginx proxy configuration in deploy/svord/nginx/hxota-proxy.conf.

§10. A-11 — Runtime-Secret Provisioning Strategy

Source: docs/remote_deploy/REMOTE_DEPLOY.md QD6

Question: How are production secrets provisioned? - **Option A:** Operator provides all secrets (HXOTA_PG_PASSWORD, HXOTA_TOKEN_SECRET, HXOTA_MINIO_USER/PASSWORD, HXOTA_ARTIFACT_PUBKEY) in the deploy env file (recommended: openssl rand -base64 48 for each) - **Option B:** Pipeline auto-generates secrets on first deploy and persists them

Recommendation: Option A (operator-provided; the pipeline is fail-closed — refuses to bring up stack with any mandatory secret unset). **Impact:** The deploy env file (scripts/testing/secrets/.hxota_deploy.env) must be populated before deploy.sh runs.

§11. A-12 — Multi-Track Toolkit Alias Provisioning

Source: PRODUCTION_READINESS_PLAN.md §2.8, K11

Question: Will the operator provision OAuth tokens for the multi-track headless workers (claude1..claude4)? - **If YES:** The automatic multi-track orchestration engine (constitution/scripts/multitrack/) engages immediately — parallel work streams can proceed. - **If NO:** All work runs sequentially in a single session; parallel track acceleration is unavailable.

Note: The engine IS bootstrapped (rc=0, cwd-hook installed, identity resolver live). Only the per-alias OAuth tokens are missing — external provisioning, cannot be automated.

Decision Checklist

ID	Decision	Answer	Date
A-01a	Permission model (RBAC-first hybrid?)	_____	
A-01b	Identity source (local/OAuth2?)	_____	
A-01c	ID type (TEXT/UUID?)	_____	
A-02a	Per-account signing keys?	_____	
A-02b	Default-account backfill?	_____	
A-03a	Website repo name?	_____	
A-03b	Containerized build?	_____	
A-03c	OpenDesign tokens-only?	_____	
A-04	Mirror-fork canonical org per submodule?	_____	
A-05	HELIX_MAX_INFLIGHT default?	_____	
A-06	ROLL-1 SuccessThreshold==0 behavior?	_____	
A-07	Signing metadata crypto-binding?	_____	
A-08a	Production host IP/hostname?	_____	
A-08b	SSH key vs password?	_____	
A-08c	Host bootstrap owner?	_____	
A-08d	Mistiq/VADER board ID + OS type?	_____	
A-09a	lets_encrypt submodule path?	_____	
A-09b	sftp submodule path?	_____	

ID	Decision	Answer	Date
A-10	hxota.dev root behavior?	_____	
A-11	Secret provisioning strategy?	_____	
A-12	Multi-track alias tokens?	_____	

Honest Boundary (§11.4.6)

Every decision above is a genuine blocking gate. None can be resolved by an agent — they require operator knowledge, preference, or external action (OAuth token provisioning, hardware, hostnames, security policy). Zero code is written under this section.